

1. 위험 API 활성화 여부 (프로젝트 단위)

API	의미
generativelanguage.googleapis.com	Gemini Developer API. 활성화 시 같은 프로젝트의 미제한 키로 Gemini 호출 가능 → 핵심 위험 지표
aiplatform.googleapis.com	Vertex AI. Gemini 외 다른 모델 포함. 정상 사용 중일 수도 있으므로 WARN

2. API Key 메타데이터 (키 단위)

각 API Key를 gcloud services api-keys list로 가져와 다음을 추출·판정합니다.

점검 항목: createTime

판정 기준: 2024-05-01 UTC 이전이면 LEGACY=YES

위험 의미: 구글의 Firebase 자동 제한 정책(24년 5월) 이전 키
→ Gemini 호출 권한이 그대로 살아있을 가능성

점검 항목: displayName 패턴

판정 기준: "auto created by Firebase", "android key auto..." 등이면 FB_AUTO=YES

위험 의미: Firebase 자동 생성 키. 공개 클라이언트(앱/웹)에 노출되어 있을 확률 매우 높음

점검 항목: Application restrictions

판정 기준: browserKey/serverKey/androidKey/iosKeyRestrictions

모두 비어 있으면 APP_RESTR=NONE

위험 의미: 어디서든 호출 가능 → 외부 탈취 시 즉시 악용 가능

점검 항목: API restrictions (apiTargets)

판정 기준: 비어 있으면 API_RESTR=UNRESTRICTED

위험 의미: 프로젝트의 모든 활성 API 호출 가능. Gemini가 켜져 있으면 자동 사용 가능

점검 항목: apiTargets allowlist

판정 기준: generativelanguage.googleapis.com이 명시 포함되어 있는지

위험 의미: 명시적으로 Gemini 호출 허용된 키 → 즉시 제거 대상

3. 최근 호출 트래픽 (프로젝트 단위, 선택)

- Cloud Monitoring serviceruntime.googleapis.com/api/request_count 메트릭으로 최근 7일간 generativelanguage.googleapis.com 요청 합계 조회
- 의도하지 않은 사용량(평소 0이었는데 갑자기 수천~수만 호출) 탐지에 사용
- 권한 없거나 --skip-metrics 옵션 사용 시 생략

4. 위험 등급 산정 로직

Gemini API가 활성화된 프로젝트 기준:

조건	등급
LEGACY + UNRESTRICTED API restrictions	CRITICAL (즉시 조치)
UNRESTRICTED API restrictions (LEGACY 아님)	HIGH
API restrictions에 Gemini 명시적 허용	HIGH
LEGACY 키이지만 일부 제한 있음	WARN
그 외	OK

Gemini API가 비활성이어도 LEGACY + UNRESTRICTED 키가 있으면 "향후 활성화 시 즉시 위험"이라는 의미로 WARN으로 분류합니다.

5. 함께 출력되는 권장 조치 (Read-only, 수동 실행)

- API restrictions 적용 (Firebase 관련 API만 허용)
- Application restrictions 설정
- 사용하지 않는 프로젝트의 gcloud services disable generativelanguage.googleapis.com
- 노출 이력 있는 키 rotate
- Billing Console에서 Generate content* SKU 비정상 과금 확인

점검에서 빠지는 항목 (권한/범위상 제외)

- API Key의 실제 키 값(AIza...) — 보안상 출력하지 않음, 키 ID/이름만 사용
- 클라이언트 코드에 키가 하드코딩되었는지 (GitHub/APK 스캔은 별도 도구 필요)
- 환불/Case 자동 오픈 — Billing Support는 사람이 수동 처리해야 함
- 조직 단위 IAM 감사 — 이번 스크립트는 Project + API Key 레이어만

첨부된 셸 스크립트를 수행하게 되면 risk -high 에 해당하는 프로젝트들 리스트가 출력됩니다.